

Audit Réglementaire Interne — ESG Flow

État réel de couverture vs promesses marketing

Audit technique — Pré-lancement

27 mai 2026

Préambule

Document interne — NE PAS DIFFUSER.

Ce document recense l'écart entre les promesses marketing de la plateforme ESG Flow et la réalité du code source au 27 mai 2026. Il sert de référence stratégique pour :

- Identifier les risques juridiques (publicité comparative trompeuse, Art. L121-1 Code conso)
- Prioriser la roadmap produit aligné avec la nouvelle grille tarifaire (249–1 199 €/mois)
- Préparer les entretiens utilisateurs ciblés
- Mesurer l'avancement futur des chantiers correctifs

Méthode : audit du code source `/Users/cisseniang/Downloads/esgplatform` (backend Python/FastAPI + frontend React/TypeScript), confrontation avec les exigences officielles de chaque réglementation. Aucune confiance accordée à la documentation marketing.

1. Résumé exécutif

Verdict global

La plateforme repose sur des fondations techniques **supérieures à la moyenne du marché** sur certains modules clés (iXBRL/ESEF, SBTi, FEC import). En revanche, **3 promesses marketing ne sont pas tenues dans le code** et créent un risque juridique et commercial significatif. De plus, **3 fonctionnalités stratégiques** sont implémentées mais sous-vendues.

Couverture par réglementation

#	Réglementation	Couverture réelle	Marketé	Gap critique
1	CSRD / ESRS	60 %	100 %	55 / 280 datapoints encodés
2	CSDDD	35 %	100 %	JSON opaque, pas de workflow d'alerte
3	BEGES (L229-25)	40 %	100 %	Aucun format de soumission ADEME
4	DPEF	65 %	100 %	Narratif templaté, pas data-bound
5	Taxonomie UE	55 %	100 %	30 / 150 activités, persistance Redis volatile
6	Sapin 2 / Vigilance 2017-399	10 %	50 %	Quasi-inexistant
7	SBTi	75 %	100 %	Meilleur module
8	SFDR	45 %	100 %	localStorage uniquement
9	Audit trail / ISAE 3000	40 %	100 %	Pas de hash chain SHA-256
10	Multi-entité / Consolidation	15 %	100 %	Schéma DB inadapté

2. Les 3 mensonges marketing à corriger

Ces promesses présentes sur la landing page ou dans les CTAs ne correspondent pas au code. **Risque juridique** (publicité trompeuse) + **risque commercial** (démonstration ratée en démo, perte de confiance).

2.1 « Audit trail SHA-256 / blockchain-grade »

- **Réalité** : Le modèle `audit_log` stocke `old_values`, `new_values`, `user_id`, `ip_address`. Aucun champ `previous_hash`, aucun service ne calcule de hash chaîné.
- **Conséquence** : Les enregistrements peuvent être modifiés individuellement sans détection. **Ne satisfait pas la norme ISAE 3000** que le Commissaire aux Comptes du client va appliquer.
- **Risque** : Vente impossible aux ETI/Groupes audit-sensibles, premier point de blocage en démo technique.
- **Reformulation immédiate suggérée** : « Journal d'audit détaillé » (vrai) ou retirer la mention « immutable / blockchain » jusqu'à l'implémentation effective.

2.2 « Multi-entité / Consolidation groupe »

- **Réalité** : Le modèle `Organization` n'a aucun `parent_id`, aucune `consolidation_method`, aucun `ownership_pct`. L'enum contient `SUBSIDIARY` mais aucune FK n'existe.
- **Conséquence** : **Aucune consolidation possible**. Aucune élimination inter-co. Le plan Groupe à 1 199 €/mois est techniquement invendable.

- **Risque** : Promesse non tenue dès la 1ère démo d'un groupe avec filiales.
- **Action** : soit retirer la promesse, soit implémenter le minimum (parent_id + roll-up simple sur indicateurs).

2.3 « Plan de vigilance Sapin 2 / Loi 2017-399 »

- **Réalité** : Couverture **10 %**. Mentions textuelles uniquement dans `reports.py:677-689` et `materiality.py:559`. Aucun module, aucune table dédiée, aucun mécanisme d'alerte.
- **Conséquence** : Sociétés mères > 5 000 salariés en France (obligation légale) ne peuvent pas couvrir leur obligation via ESG Flow.
- **Risque** : Client refusera dès la lecture du cahier des charges.
- **Action** : retirer la promesse ou créer un module minimal (table `vigilance_plans` + cartographie risques + plan d'action + mécanisme d'alerte).

3. Les 3 pépites cachées à amplifier

Ces fonctionnalités existent dans le code, fonctionnent, et constituent un avantage compétitif réel face à Greenly, Sweep, Persefoni. Elles méritent d'être mises en avant sur la landing.

3.1 Générateur iXBRL / ESEF réel

- **Fichier** : `backend/app/services/ixbrl_service.py` (580 lignes)
- **Caractéristiques** : Génération XHTML balisée avec le namespace EFRAG `2024-12-31`, 35 concepts ESRS encodés.
- **Différenciation** : 90 % des concurrents (Greenly, Sweep) produisent du PDF déguisé. ESG Flow produit le XHTML certifiable réel.
- **Argument commercial** : « ESG Flow est l'une des rares solutions à produire un XHTML iXBRL conforme au format EFRAG, exigé par l'ESMA à partir de 2026 pour les sociétés cotées. »

3.2 Import FEC → Calcul Scope 3 automatique

- **Fichiers** : `backend/app/services/fec_parser.py`, `backend/app/services/pcg_emission_mapper.py`
- **Caractéristiques** : Parser FEC 18 colonnes (Sage, Cegid, Pennylane), mapping automatique des comptes PCG (classe 60, 61, 62) vers les facteurs d'émission ADEME (47 facteurs encodés).
- **Différenciation** : Vrai workflow d'import, pas de simple template. Évite 200 à 400 heures de saisie manuelle par exercice.
- **Argument DAF** : « Importe ton FEC, on calcule ton Scope 3 en 5 minutes au lieu de 3 mois. »

3.3 Préflight SBTi avant paiement du fee 9 500 USD

- **Fichier** : `backend/app/services/sbti_service.py`

- **Caractéristiques** : Validation des critères v5.2 (réduction minimale 4.2 %/an pour la trajectoire 1.5 °C, scope 3 ≥ 40 % du total, net-zero ≤ 2050).
- **Différenciation** : Aucun concurrent ne propose ce préflight. Le SBTi rejette ~30 % des soumissions à la 1ère revue.
- **Argument** : « Validation préalable avant de payer les 9 500 USD au SBTi. »

4. Détail de couverture par réglementation

4.1 CSRD / ESRS — 60 %

Code existant :

- Backend : `endpoints/esrs.py` (398L, 11 standards E1-E5/S1-S4/G1/ESRS2)
- Service taxonomie : `services/esrs_taxonomy.py` (548L) — **55 ESRSConcepts** sur ~1 000 publiés par EFRA
- Service iXBRL : `services/ixbrl_service.py` (580L, namespace EFRA 2024-12-31)
- Frontend : `Compliance/ESRSEnvironmental.tsx`, `ESRSSocial.tsx`, `ESRSGovernance.tsx`, `ESRSWaterWaste.tsx`, `ESRSGapAnalysis.tsx`, `IXBRLTagging.tsx` (950L), `Reports/CSRDBuilder.tsx`

Gaps critiques :

- Seulement **55 / 280 datapoints obligatoires** encodés (~20 %)
- L'analyse de gap est **heuristique** : `covered = round(matching * 0.5)` (`esrs.py:306`) — n'est PAS un suivi disclosure-par-disclosure
- Pas d'intégration Arelle pour la validation XSD
- Pas de support des standards sectoriels (ESRS sectoriels en cours de publication)

Sévérité : HAUTE — un client soumis à la CSRD vague 2026 verra le manque dès le 1er audit interne.

4.2 CSDDD — 35 %

Code existant :

- Backend : `endpoints/csddd.py` (199L) — un seul GET/POST persistant un JSON opaque dans `framework_assessments`
- Catalogue de 18 risques (UNGP / OECD / ILO / REACH)
- Frontend : `Compliance/CSDDD.tsx` (794L)

Gaps critiques :

- Pas de table dédiée pour les griefs (juste un array JSON)
- Pas de workflow de plainte anonyme
- Pas de suivi de plan d'action
- Pas de cartographie de chaîne de valeur au-delà de la liste fournisseurs
- Pas d'export annuel pour reporting CSDDD

Sévérité : HAUTE — CSDDD entre en vigueur 2027 pour ~15 000 entreprises EU.

4.3 BEGES (L229-25) — 40 %

Code existant :

- Backend : `endpoints/carbon.py` (351L) — split Scope 1/2/3
- Service Scope 3 : `services/scope3_calculator.py` — 47 facteurs ADEME, 15 catégories GHG Protocol
- Parsers : `services/fec_parser.py` , `services/pcg_emission_mapper.py`

Gaps critiques :

- Pas d'export `BEGES.xlsx` (template officiel ADEME)
- Pas de format de soumission `bilans-ges.ademe.fr`
- Pas de gestion de l'incertitude (%)
- Pas de politique de recalcul (baseline reset)
- Pas d'attestation ISO 14064 audit

Sévérité : HAUTE — argument commercial DAF si corrigé.

4.4 DPEF — 65 %

Code existant :

- `services/report_service.py:1281` `_generate_dpef_pdf` — vrai générateur ReportLab
- Frontend : `DPEFReport.tsx` (1 035 lignes)

Gaps critiques :

- Business model, cartographie risques, KPIs sont des narratifs templatés, non dérivés de champs DB structurés

Sévérité : MOYENNE — DPEF est en cours de remplacement par CSRD.

4.5 Taxonomie UE — 55 %

Code existant :

- Backend : `endpoints/taxonomy.py` (414L) — 6 objectifs, **30 activités de référence** hardcodées
- Endpoint `/assess` : calcule turnover/capex alignment %
- Endpoint `/activities/{id}/dnsh` : retourne les critères DNSH
- Frontend : `Compliance/TaxonomyAlignment.tsx` (1 104 lignes)

Gaps critiques :

- 30 / ~150 activités (Annexes I & II) hardcodées
- Minimum safeguards = booléen seulement
- Pas de calcul KPI OpEx
- **Persistance en Redis** — volatile, non auditable

Sévérité : HAUTE — Taxonomie UE obligatoire pour les sociétés sous CSRD.

4.6 Sapin 2 / Vigilance 2017-399 — 10 %

Code existant :

- Mentions textuelles uniquement dans `reports.py:677-689` et `materiality.py:559`

Gaps critiques :

- Aucun module dédié
- Aucune table dédiée
- Aucun plan de vigilance structuré
- Aucun mécanisme d'alerte

Sévérité : HAUTE — obligation légale pour groupes français > 5 000 salariés.

4.7 SBTi — 75 %

Code existant :

- Backend : `endpoints/sbti.py` (292L) — CRUD complet + validate + submit
- Service : `services/sbti_service.py` — validation critères v5.2
- Modèle : `SBTiCommitment` avec lifecycle states (draft → validated → submitted → approved)

Gaps critiques :

- Pas de pathway sectoriel SDA (Sectoral Decarbonization Approach)
- Trajectoire de décarbonation pas visualisée en DB

Sévérité : BASSE — meilleur module de la plateforme.

4.8 SFDR — 45 %

Code existant :

- Frontend : `Compliance/SFDRDisclosure.tsx` (730L) — 21 indicateurs PAI (couvre les 14+4 obligatoires)
- Templates Article 6/8/9
- Export PDF côté client

Gaps critiques :

- **Persisté en localStorage** uniquement (perdu au reload)
- Pas de planification des reportings périodiques
- Pas de modèle entité fund-level

Sévérité : MOYENNE — cible niche (asset managers).

4.9 Audit Trail / ISAE 3000 — 40 %

Code existant :

- `models/audit_log.py` : old_values, new_values, user, IP, user_agent

Gap critique :

- **Pas de hash chain SHA-256** (pas de champ `previous_hash`)
- L' `integrity_hash` référencé dans `audit_trail.py:124` lit depuis `entry_metadata` mais aucun service ne le calcule ni ne le chaîne
- Les enregistrements sont **individuellement modifiables**
- **Ne satisfait PAS la norme ISAE 3000**

Sévérité : CRITIQUE — chantier P0 absolu.

4.10 Multi-entité / Consolidation — 15 %

Code existant :

- Modèle `Organization` avec enum `SUBSIDIARY`

Gaps critiques :

- Pas de `parent_id` (FK)
- Pas de `consolidation_method`
- Pas d' `ownership_pct`
- Pas d'élimination inter-co
- Pas d'endpoint de rapport consolidé

Sévérité : HAUTE — bloque le plan Groupe 1 199 €/mois.

5. Limites architecturales

- **Persistance Redis volatile** : `taxonomy.py:17` , certains plans carbon — perdu au redémarrage, non multi-tenant safe, non auditable
- **localStorage frontend** : SFDR — perdu au reload, non synchronisable multi-device
- **6+ fichiers `.backup` / `.bak`** dans `models/` et `services/` (esrs_taxonomy, materiality, role, user) — hygiène production
- **Scripts `seed_.py` et `fix_.sh` à la racine** — opérations manuelles, pas de discipline migrations
- **Pas de worker pour exports lourds** : un iXBRL de 1 000+ faits bloquerait le thread requête FastAPI
- **materiality.py** : champs `financial_impact` / `esg_impact` sont des floats, mais pas de colonne `iro_type` en DB (seulement inféré côté frontend)

6. Roadmap recommandée 90 jours

Priorisation ROI / coût de développement :

Priorité	Chantier	Coût dev	Impact vente
P0	Hash chain SHA-256 audit trail (ISAE 3000)	3–5 j	Débloque ventes ETI/Groupe
P1	Multi-entité minimal (parent_id, roll-up)	7–10 j	Débloque plan Groupe 1 199 €
P2	ESRS datapoints étendus (55 → 150)	10–15 j	CSRD défendable
P3	Module vigilance Sapin 2 réel	7–10 j	Élimine risque légal + débloque marché
P4	Format BEGES.xlsx ADEME	5 j	Killer feature DAF
P5	Persistance SFDR + Taxonomie (sortir de Redis)	3–5 j	Hygiène + multi-tenant safe
P6	Étendre Taxonomie UE (30 → 150 activités)	10 j	Sociétés CSRD obligées

Total estimé : 45–60 jours dev, soit 9–12 semaines à 1 dev.

7. Hypothèses à valider en entretien utilisateur

Chaque gap critique doit être traité comme une **hypothèse** plutôt qu'une certitude. Avant de coder, valider via 15–20 entretiens prospects :

Hypothèse à valider	Question d'entretien
Le hash chain SHA-256 est exigé par les CAC	« Que demande ton commissaire aux comptes en matière de traçabilité ESG ? »
Le multi-entité est un besoin réel (vs simple regroupement)	« Combien de filiales reportes-tu ? Comment fais-tu aujourd'hui ? »
Le format BEGES.xlsx est obligatoire pour soumission ADEME	« Comment soumetts-tu ton bilan GES à l'ADEME ? »
Les 280 datapoints ESRS sont vraiment nécessaires (vs 55 bien choisis)	« Lesquels parmi les ESRS te causent le plus de difficulté ? »
Sapin 2 / vigilance est un sujet pour le buyer persona	« Es-tu soumis à la loi 2017-399 ? Comment gères-tu ton plan ? »
iXBRL est compris et valorisé par les prospects	« Connais-tu le format ESEF iXBRL ? Comment le génères-tu ? »

8. Annexes

8.1 Fichiers clés à connaître

backend/app/services/ixbri_service.py	(580L)	– Générateur iXBRL/ESEF
backend/app/services/esrs_taxonomy.py	(548L)	– 55 ESRSConcepts
backend/app/services/fec_parser.py		– Parser FEC 18 colonnes
backend/app/services/pcg_emission_mapper.py		– Mapping PCG → ADEME
backend/app/services/scope3_calculator.py		– 47 facteurs ADEME
backend/app/services/sbti_service.py		– Validation v5.2
backend/app/services/report_service.py	(~3500L)	– Génération PDF
backend/app/api/v1/endpoints/esrs.py	(398L)	– API ESRS
backend/app/api/v1/endpoints/csddd.py	(199L)	– API CSDDD
backend/app/api/v1/endpoints/taxonomy.py	(414L)	– API Taxonomie UE
backend/app/api/v1/endpoints/sbti.py	(292L)	– API SBTi
backend/app/models/audit_log.py		– Audit trail (sans hash chain)

8.2 Légende couverture

- **0 %** : Inexistant
- **25 %** : Placeholder / texte uniquement
- **50 %** : Implémentation basique fonctionnelle
- **75 %** : Fonctionnel avec workflow complet
- **100 %** : Production-ready avec audit trail conforme

8.3 Document de référence

- EFRAG : ESRS Set 1 (Final Draft, novembre 2022) — 12 standards
- Commission Européenne : Règlement délégué 2023/2772 (juillet 2023)
- AMF : Position-recommandation DOC-2024-04 (Mai 2024)
- ADEME : Guide BEGES version 5 (2022)
- Loi française 2017-399 (Devoir de vigilance, 27 mars 2017)

Document confidentiel — Diffusion interne uniquement.

Audit réalisé le 27 mai 2026.